CSIT970 Security Essentials

Week 2 – Cyber Threats

Dr. Steven Duong

School of Computing and Information Technology

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Cyber threats in 2025–26: key trends

- Phishing and account compromise still drive many incidents
- Ransomware remains one of the most disruptive cybercrime threats
- Info-stealer malware is now a major pathway to larger breaches
- Third-party and supply-chain risk is increasing
- AI is helping attackers scale phishing and social engineering

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Cybercrime

- The use of computers or networks to commit crimes
- Examples include fraud, online abuse, identity theft, and threats or intimidation
- Common targets include individuals, businesses, educational institutions, and governments
- Cybercrime is becoming more scalable, more professional, and more damaging

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Criminal Infrastructure

- **Botnet herders** – control compromised devices
- **Malware writers** – develop and maintain malicious code
- **Spam and phishing operators** – distribute scams and malware
- **Info-stealer operators/initial access brokers** – steal and sell credentials or access
- **Cashout operators** – convert stolen data or funds into profit

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Botnet: Concept

- A botnet is a network of compromised computers and internet-connected devices
- The attacker controls the botnet remotely through command-and-control (C2) infrastructure
- This diagram shows one common centralised botnet model

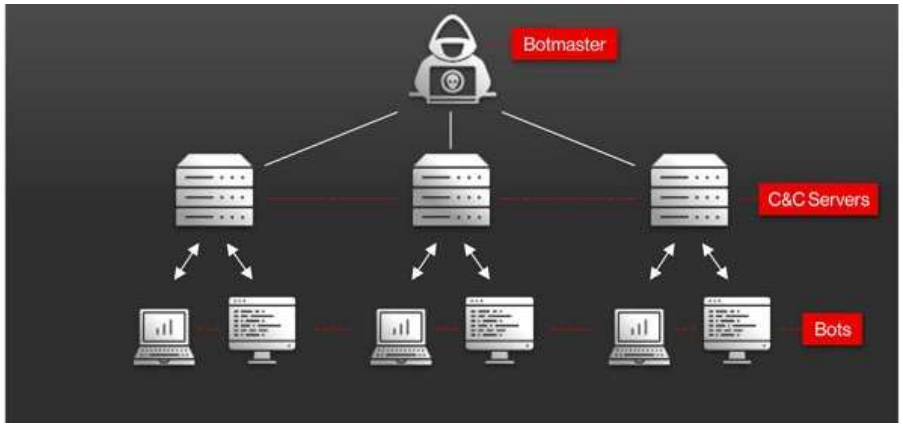

Image courtesy: Crowdstrike

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Botnet: How it works?

- **Infection**: devices are compromised through phishing, malicious downloads, default credentials, exposed services, or unpatched vulnerabilities
- **Command and control**: infected devices connect back to attacker-controlled infrastructure for instructions
- **Common uses:**
  - Distributed Denial of Service (DDoS) Attacks
  - Spam and phishing distribution
  - Credential theft or malware delivery
  - Proxying criminal traffic anonymously
  - Cryptomining or other resource abuse

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Botnet: Some Well-Known Botnets

- **Storm botnet**
  - Early large-scale botnet spread mainly through malicious email attachments and social engineering
  - Important because it showed the move toward more resilient botnet control
  - Good historical example of the shift from “mischief” to financially motivated cybercrime

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Botnet: Some Well-Known Botnets

- **Conficker botnet**
  - Worm that spread through the Windows MS08-067 vulnerability and other propagation methods
  - Used algorithmically generated domains to make command-and-control harder to block
  - Important example of why coordinated industry and defender response matters

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Botnet: Some Well-Known Botnets

- **Mirai botnet**
  - Mirai is a family of IoT botnets targeting devices such as IP cameras, DVRs (digital video recorders), and home routers
  - It scans for vulnerable devices and commonly exploits default or weak credentials
  - Mirai became famous for showing how insecure IoT devices can be used in very large DDoS attacks
  - It remains an important reference point for understanding modern IoT botnets

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Botnet: Mitigating Botnet Infection

- Disrupt command-and-control infrastructure where possible
- Clean infected devices and reset compromised credentials
- Patch software and firmware promptly
- Replace end-of-life devices
- Disable remote administration and unused services
- Change default passwords

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Botnet: Difficulties of fixing botnet infection

- Many infected devices are unattended or poorly managed
- Some devices are already end-of-life and cannot be secured well
- Users may not notice infection or know how to remediate it
- Consumer IoT and home-network devices are widely distributed across many owners and countries
- Some devices may arrive pre-compromised or become compromised during setup

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which of the following best describes a botnet?

A. A secure network used by organisations to manage software updates

B. A group of compromised devices remotely controlled by an attacker

C. A firewall rule set that blocks malicious traffic automatically

D. A type of antivirus software used to detect worms

E. A backup system used to recover from ransomware

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Why did Conficker's domain generation algorithm (DGA) make the botnet harder to disrupt?

A. It allowed Conficker to encrypt all files on the victim's computer

B. It allowed the malware to spread only through USB drives

C. It made infected machines generate many possible domains for command and control

D. It prevented defenders from patching Windows systems

E. It disabled antivirus software permanently

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which of the following is the best combination of measures to reduce botnet infections?

A. Ignore firmware updates and only install antivirus software

B. Change default passwords, patch software and firmware, and disable unused remote administration

C. Use the same password on all devices so they are easier to manage

D. Restart the device once a year without changing any settings

E. Only disconnect the internet when an attack is already happening

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Malware developers/operators

- Malware development often involves specialised roles
- Common tasks include:
  - turning vulnerabilities into working exploits
  - building loaders, droppers, or downloaders
  - developing backdoors, RATs, infostealers, or ransomware payloads
  - creating resilient command-and-control mechanisms
  - designing payloads for theft, surveillance, disruption, or monetisation
- Attribution and arrest are often difficult across jurisdictions

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Mobile malware

- Unsupported or unpatched mobile devices increase security risk
- Malicious, repackaged, or sideloaded apps are a major infection path
  - Google 2025: prevented more than 1.75 million policy-violating apps, banned more than 80,000 bad developer accounts (https://security.googleblog.com/2026/02/keeping-google-play-android-app-ecosystem-safe-2025.html)
- Mobile malware may steal data, spy on users, commit fraud, or install more malware
- Targeted mobile spyware is also an important modern threat

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Staged malware delivery: loader/dropper

- A **dropper** is malware whose job is to install or release another malware payload
- A **downloader** retrieves additional malware from the internet
  - Common delivery methods include:
  - phishing attachments or malicious files
  - malicious links or drive-by downloads
  - trojanised software or fake installers
  - exploits against vulnerable systems

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Payload

- The payload is the part that performs the attacker's objective
- Common payload goals include:
  - stealing credentials or session tokens
  - exfiltrating sensitive data
  - encrypting data for ransomware
  - spying on the victim or logging activity
  - installing persistence or additional malware
  - abusing system resources, such as cryptomining

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

What is the main role of a dropper in a malware attack?

A. To encrypt files and demand ransom

B. To install or release another malware payload

C. To block antivirus software permanently

D. To create security patches automatically

E. To remove all traces of the attack immediately

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which of the following is the best example of a malware payload?

A. A fake installer that delivers malware onto a computer

B. A phishing email attachment used to start an infection

C. A malicious program that steals passwords and session tokens

D. A link that redirects a user to a harmful website

E. A downloader that fetches malware from the internet

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which statement best explains the difference between a dropper and a downloader?

A. A dropper steals data, while a downloader encrypts files

B. A dropper installs another malware payload, while a downloader retrieves additional malware from the internet

C. A dropper is only used in ransomware, while a downloader is only used in spyware

D. A dropper spreads by itself across networks, while a downloader removes malware

E. A dropper only works on mobile phones, while a downloader only works on desktop computers

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which of the following is the best example of staged malware delivery?

A. A user installs a legitimate app from a trusted source and updates it regularly

B. A device receives a security patch that fixes a known vulnerability

C. A phishing attachment runs a dropper, which then installs ransomware on the victim's computer

D. A firewall blocks suspicious traffic from an unknown IP address

E. A user changes their password after a data breach notification

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Spam Senders

- Early stage
  - Early spam campaigns were relatively small and often email-centric
  - Phishing lures in the early 2000s helped spam become more profitable
- How defenders responded
  - Large email providers such as Gmail, Yahoo, and Outlook.com deployed filtering at scale
  - Modern defenses also rely on sender authentication, reputation, and machine learning.
- Cat-and-mouse game
  - Spam and phishing remain highly adaptive
  - Attackers constantly change wording, links, domains, and delivery methods to bypass filters

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Cashout Operators

- **How cashout evolved**
  - **Earlier phase**: criminals used stolen card details or bank fraud to buy goods or move money indirectly
  - **Mid-2000s**: criminals increasingly used money mules to receive and transfer stolen funds
  - **Today**: cybercriminals often use cryptocurrency to move or store criminal proceeds
- **Current reality**
  - Cryptocurrency can help criminals move money quickly across borders
  - But crypto transactions are pseudonymous, not fully anonymous
  - Exchanges, KYC (know your customer)/AML (anti-money laundering) rules, and blockchain tracing have made cashout riskier for offenders

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Example: WannaCry Ransomware Attack

- Global ransomware outbreak in May 2017
- Targeted Windows systems, especially unpatched ones
- Combined file encryption with worm-like self-spread
- Exploited the SMBv1 vulnerability patched by MS17-010
- Demanded ransom payment in Bitcoin

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Some Major Cyber Threat Trends

- Ransomware
- Hacktivism
- Surveillance and targeted spyware

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Ransomware

- Ransomware is malware used to extort victims
- It may **encrypt data, disrupt systems**, or **threaten to leak stolen data**
- Victims are pressured to pay for decryption, restoration, or non-release of data
- Payment is often requested in cryptocurrency, which is pseudonymous, not fully anonymous

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Ransomware

- **Payment methods**
  - Ransomware groups usually demand payment in cryptocurrency
  - Cryptocurrency helps move money quickly, but it is increasingly traceable
- **How ransomware is operated**
  - Some low-end campaigns are closer to scareware or poorly implemented extortion
  - Many modern groups use Ransomware-as-a-Service (RaaS)
  - In RaaS, core operators provide the malware and infrastructure, while affiliates carry out attacks

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Ransomware and critical sectors

- Public-sector and healthcare organisations remain high-value ransomware targets
- Attacks can cause service disruption, not just data loss
- Healthcare incidents can affect billing, prescriptions, appointments, and patient operations
- Many groups now use double extortion: encrypting systems and threatening to leak stolen data
- In Australia, mandatory ransomware payment reporting became active in May 2025 for covered entities
  - https://www.cyber.gov.au/about-us/view-all-content/reports-and-statistics/annual-cyber-threat-report-2024-2025

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Hacktivism

- Hacktivism is politically or ideologically motivated online activity
- It often uses online media to mobilise people and spread messages
- Common methods include:
  - denial-of-service attacks
  - website defacement
  - hack-and-leak operations
  - doxxing and harassment

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Hacktivism: consequences

- **Denial-of-service**
  - attacks can interrupt websites, portals, or online services
- **Brand damage**
  - doxxing and public exposure can damage reputation
  - it can also cause distress to executives and staff
- **Public pressure**
  - social media can quickly amplify a technical incident into a reputational crisis

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Hacktivism: targeting organisations

- Governments and public-facing organisations are common targets
- Companies can also be targeted, especially high-profile ones
- Social media can amplify the impact of attacks or leaks
- Even simple attacks can create operational disruption and reputational harm

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Mass Surveillance

- Governments have a range of tools for both **passive surveillance of networks** and **active attacks on computer systems**
- The Snowden disclosures revealed major surveillance activities associated with **Five Eyes** countries
- A large **surveillance business** sells equipment for wiretapping, radio intercept, and device exploitation
- As privacy becomes more important, it is useful to understand both **historical mass surveillance** and **modern targeted surveillance**

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Mass Surveillance Technology: PRISM

- Purpose
  - PRISM was a program disclosed in 2013 for collecting certain **internet communications from U.S. providers**
- Operation
  - It provided a structured way for intelligence agencies to obtain data under U.S. legal authority
- Key point
  - PRISM should be kept separate from the separate Verizon phone-metadata disclosure
  - A system many people understood as targeted surveillance also raised concerns about collection at scale

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Mass Surveillance Technology: Tempora

- Purpose
  - A program to **collect intelligence from international fibre-optic cables**
- Operation
  - Large volumes of cable traffic were collected and reduced using filters
  - Material was then selected using **selectors**, not only phone numbers but also search terms such as IP addresses
- Key point
  - Surveillance can happen at the **network backbone**, not only on end devices

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Mass Surveillance Technology: Muscular

- Purpose
  - To collect data as it flowed between the **data centres** of large service firms such as Google and Yahoo
- Operation
  - User traffic may have appeared encrypted at the front end, but internal or inter-data-centre links were the weak point at the time
- Modern update
  - Today, providers widely encrypt internal traffic, and CDN-to-origin encryption is commonly supported
- Key point
  - User-visible encryption does not automatically guarantee confidentiality across every internal link

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Mass Surveillance Technology: Bullrun and Edgehill

- Purpose
  - **Tampering with cryptography** through suppliers, standards, and implementations at multiple levels of the stack
- Operation
  - Influencing standards, exploiting implementation weaknesses, and working through trusted suppliers
  - Bullrun was the NSA codename; Edgehill was the GCHQ codename
- Example
  - The Dual_EC_DRBG controversy became the most famous example in this area
- Key point
  - Strong cryptography depends not only on mathematics, but also on trustworthy standards and supply chains

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Mass Surveillance Technology: XKeyScore

- Purpose
  - NSA's **search and analysis system**
- Operation
  - Analysts could search collected data such as emails, chats, browsing histories, and selectors
  - It could also support **target discovery** and pattern analysis
- Extraction
  - Tasked items could be extracted and forwarded to whoever requested them
- Key point
  - Once data is collected at scale, search systems make it far more operationally useful

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Modern update: targeted spyware

- Modern surveillance is not only about backbone collection
- Mercenary spyware targets specific phones and accounts
- Typical targets include journalists, activists, politicians, and diplomats
- These attacks are highly targeted, expensive, and difficult to detect
  - https://support.apple.com/en-us/102174
- Main lesson: surveillance today is both broad and highly targeted

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which statement best describes modern ransomware?

A. It only locks the screen and never affects files

B. It only spreads through USB drives

C. It may encrypt data, disrupt systems, and threaten to leak stolen data

D. It only targets personal laptops, not organisations

E. It always guarantees recovery once payment is made

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

What is the best description of Ransomware-as-a-Service (RaaS)?

A. A free antivirus service provided by governments

B. A model where core operators provide ransomware tools and affiliates carry out attacks

C. A backup service that automatically restores encrypted data

D. A legal cloud storage service for incident response teams

E. A payment platform that only works with Bitcoin

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which of the following is the best example of hacktivism?

A. A company patching its servers after a security audit

B. A politically motivated group launching a DDoS attack against a government website

C. A student forgetting their password and being locked out

D. A bank using multi-factor authentication for employees

E. A software company releasing a new mobile app

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

What is the main lesson of the MUSCULAR case study?

A. HTTPS always guarantees full end-to-end privacy across all infrastructure

B. Encryption only matters for passwords, not for email

C. User-visible encryption does not always mean every internal network link is protected

D. Websites cannot be monitored once they use cloud hosting

E. Only mobile phones can be targeted by surveillance programs

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which statement best describes mercenary spyware?

A. It is harmless advertising software installed in free apps

B. It is low-cost malware mainly used for sending spam emails

C. It is highly targeted spyware used against specific individuals such as journalists, activists, or politicians

D. It only affects desktop computers in corporate offices

E. It is a legal monitoring tool used only for parental control

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

QUIZ

Which pairing is most accurate?

A. PRISM — ransomware payment platform

B. XKeyScore — search and analysis system for collected data

C. Tempora — antivirus tool for protecting fibre-optic cables

D. MUSCULAR — public bug bounty program

E. Bullrun — phishing detection software

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Lab Attendance and Submission

- Lab attendance is compulsory. If you are unable to attend, please apply for Academic Consideration (AC) in advance
- You should submit your work during the lab on submission link provided for each week

UNIVERSITY OF WOLLONGONG AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from Steven Duong

Quiz on Week 3

- To be done during the lab and at the lab
- Closed book
- Contents include materials from lectures of Week 1+2, and Labs of Week 2-3.

This slide is copyrighted. It must not be distributed without permission from Steven Duong